

# USER MANAGEMENT

## Specifications

### User Authentication

There are two types of authentication:

- Credential-based: simple login/password with 2FA (sending a code per email to verify the user's identity)
  - The users that authenticate using credentials are managed by the systems internal user Database, they are called "Internal Users"
  - Passwords are encrypted
- SSO: the user's credential are controlled by a 3<sup>rd</sup> party authority using OAuth. These users are called "AD Users"

### User Authorization

User authorizations are assigned by roles. A user can have one or many roles. Each role provides access to a set of features of the system (both front-end and back-end).

### Roles

There are three basic roles:

- Admin: the users with the Admin role can manage users
- Power-user: the users with the "Power-user" role have access to some specific features of the system (agent creation, tools creation, etc.)
- User: the users with the "User" role have access to the chatbot and a limited set of features (preferences, agent log, etc.)

In all functions that manage users throughout the system, a user **MUST** always have at least one role.

### Configuring Roles

In the "Settings" Menu (located at the bottom left of the application's screen), a new tab is created. This tab can be accessed by and is visible only to Admins. This is where Roles Management is handled by Admins.

An Admin can create a new role. They specify:

- The role name
- A short description
- The features to which the role has access

An Admin can update a role by selecting other features or deselecting features the role has access to.

The “User” role cannot be deleted. An Admin can delete a role, except of course the “User” role.

When an Admin deletes a role, all users this role is revoked for all users that have it.

- If a user has only the deleted role, then he gets the “User” role assigned in place of the revoked role.
- If a Role is deleted, any AD Group Mappings targeting that Role must be automatically updated to the default 'User' role.

## Group Mapping

### *AD Group Discovery (Lazy Loading)*

To avoid manual errors in group naming, the system automatically builds a catalog of "Known AD Groups" based on user activity.

- **Discovery Mechanism:** Every time an AD User successfully logs in via SSO, the system inspects the groups claim in their security token.
- **Cataloging:** Any AD Group identifier (Name or Object ID) found in the user's token that is not already present in the system's "Known AD Groups" list is automatically added to the list.
- **Data Stored:** The system stores only the Group Identifier (and Group Name if available in the token) to facilitate mapping. No other group metadata is required.

### *Roles assignment to groups*

For AD users, the Admin can assign a default set of roles for groups.

The “Settings menu” provides a dedicated tab for group mapping, accessible only to Admins.

From there, the Admin is presented with a **searchable dropdown list** (Autocomplete) populated by the "Known AD Groups" catalog.

If an Admin wishes to map a group that has not yet been "discovered" (because no user from that group has logged in yet), the interface allows them to manually type the AD Group String and save it. These are visually marked as "Manually Added".

Once a group is selected or entered, the Admin assigns a default set of roles that members of this group will inherit.

The Admin can also view the list of AD groups to which roles have been assigned and modify the list of roles of an AD Group (Add a new Role, Revoke a Role).

Users of an AD Group will inherit any change to the roles assignments of this AD Group.

- Note: Synchronization of AD Groups and Roles occurs only when the user logs in (token issuance). If critical permissions are revoked in AD, the user will retain them in the system until their current session expires and they are forced to re-authenticate.

Roles assigned to users through AD group mapping are read-only in the User Management UI.

## User Interface

In the “Settings” Menu (located at the bottom left of the application’s screen), a new tab is created. This tab can be accessed by and is visible only to Admins. This is where User Management is handled by Admins.

## Creating users

### *Internal Users*

Internal Users can be created in two ways:

- Request from the user:
  - Upon first access to the system, a user is presented with the option to create an account.
  - Creating an account requests the user to enter his first name, last name, email address, a login, a password (twice for control).
  - Once the user has validated this information, the system sends an email with a link to the email address provided to validate the email.
  - Once the user has validated his email address by clicking on the link he is registered. He receives another email informing him that an admin will review his credentials and validate his request.
  - All admin users receive an email with the information related to the requesting user along with a link to approve this user.
  - This link leads to a page requesting the Admin to approve or refuse the user and, if he selected “Approve” to assign a set of roles to the user.
  - The decision of the admin is sent per email to the user (including notification of his roles if his request is approved).
  - If the user is approved he can access the system.
- Creation by the Admin:
  - The admin has the ability to create a new Internal User through the User Management Interface.
  - When he creates a new Internal User, he has to enter the first name, last name, email, login, initial password of the user, the roles of the user.
  - When he validates the user is immediately approved.
  - When the user has been created by the admin he receives an email with confirmation of his access and his roles.

## AD Users

As their name implies, AD users are Active Directory users.

AD Users are not “created” per se as they already exist in the AD directory.

When an AD user first accesses the system, his reference record is automatically created into the internal User database of the system.

If this AD user is part of AD Groups for which roles have been mapped, he inherits automatically the roles mapped to these groups.

If this AD user is not part of any AD group for which roles have been mapped, the user is created but assigned **No Role** (or a 'Pending' status). They cannot access the systems features until an Admin manually assigns a role or maps their group.

The internal User DB of the system will simply record a reference to the AD record corresponding to the selected user, along with its roles.

This user will be authenticated using SSO/oAuth.

## Updating User Information

### Internal Users

When an Internal User accesses the system he has to log-in. From the login popup he can request to change his password:

- He will receive a link to a form where he can update his password (double entry for confirmation)

When an Internal User is logged-in, he can access the configuration of his account through the “Settings menu”. There is a dedicated tab for this where the user can:

- Change his email address
- Change his password (double entry for confirmation)

For an Admin, the “User Management” Admin User Interface provides the following features:

- Display the list of Internal Users. This list displays: First name, Last Name, email address, Active / Inactive. This list can be filtered by any column. The Admin can select an option to show only active users or only inactive users
- Select an Internal User for update. Then the Admin can update the First Name, The last Name, The email address and the roles assigned to this user

## AD Users

There is a dedicated UI for the admin (as part of the User Management UI) for AD Users where the Admin can:

- View the list of AD users registered into the System
- This list displays all AD user information (First name, Last Name, Organization, email address, Active / Inactive, Roles).
- This list can be filtered by any column. The Admin can select an option to show only active users or only inactive users or users that have “No role”.
- Select a user and change the roles assigned to this user. BEWARE: roles mapped through Group Mapping are read-only and the Admin cannot change them for a given user. However, the Admin can assign or revoke additional roles for a specific user.

### *Deleting a user*

Users are NEVER deleted from the system, but only marked as “Inactive”.

### *Internal Users*

For an Admin, the “User Management” Admin User Interface provides the ability to “Inactivate” an Internal User. This is done by selecting the user into the user list and toggling the “Activation” of the user.

Similarly, the Admin can “re-activate” an Internal User.

### *AD Users*

For an Admin, the “User Management” Admin User Interface provides the ability to “Inactivate” an AD User. This is done by selecting the user into the user list and toggling the “Activation” of the user.

Similarly, the Admin can “re-activate” an AD User.

If a user is disabled in AD, Microsoft/AD will refuse to issue the OAuth token, and he cannot log in to the system.

If an AD User logs in and an Internal User with the same email already exists, the system updates the authentication method of the existing record to 'SSO' and retains the history/roles.

## Configuration of OAuth

The “Settings Menu” allows the Admin to configure OAuth.

A dedicated tab is available only to the Admin. The tab displays the **Redirect URI** (Read-Only) that the Admin must copy to their Identity Provider configuration. The Admin must enter the Client ID, Client Secret, and Tenant URL provided by the Identity Provider.